TrailSearch

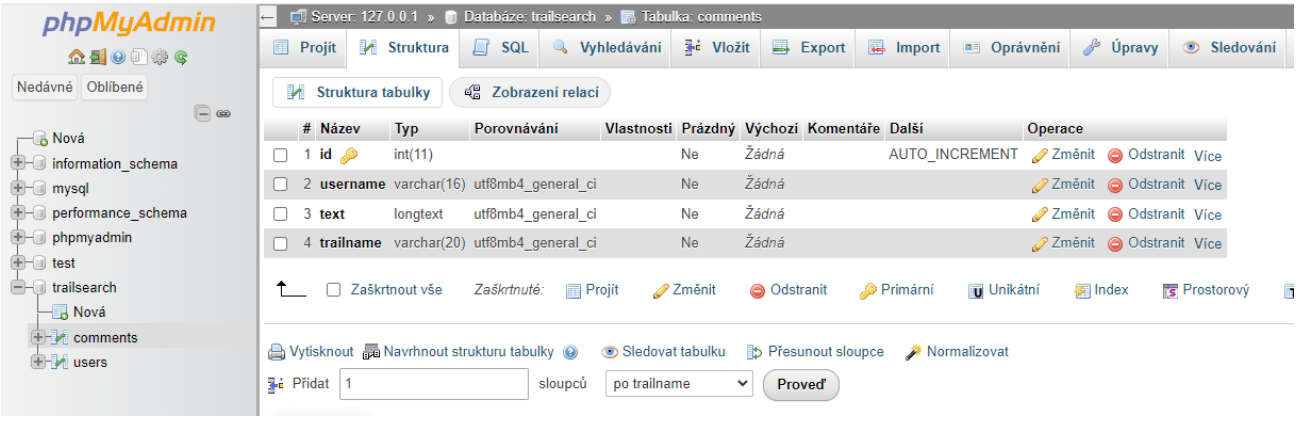
Programátorská dokumentace

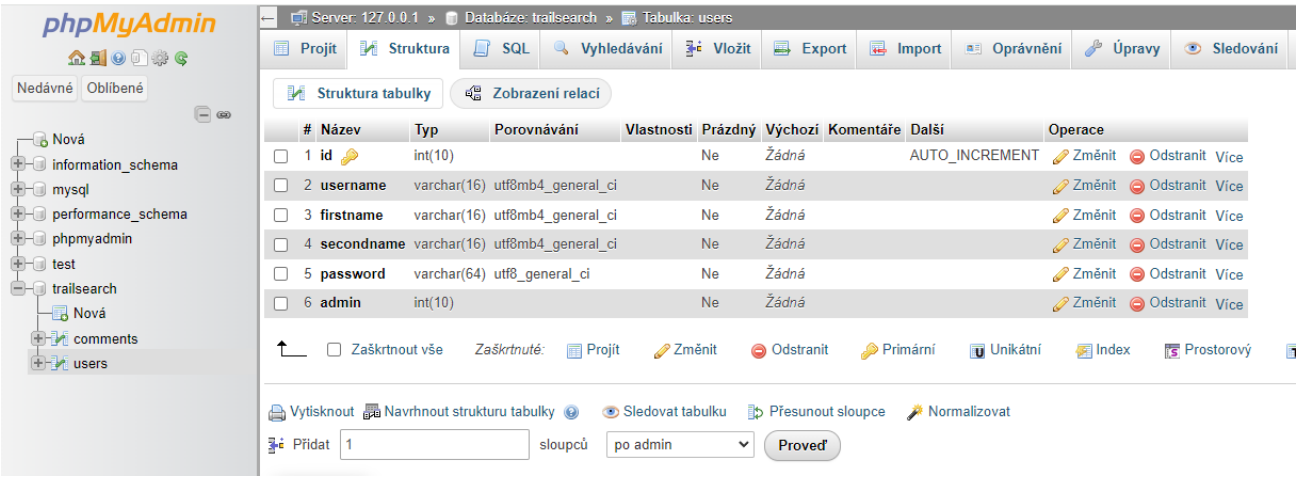
Brtna Matouš
16.12.2023

1. Úvod

TrailSearch je webová aplikace, která byla navržena pomocí jazyků HTML, CSS JAVASCRIPT a PHP. Databáze uživatelů je realizována v MySQL.

Databáze obsahuje pouze dvě tabulky. První tabulka „users“ slouží k ukládání členů a druhá tabulka „comments“ slouží k ukládání všech cvložených komentářů

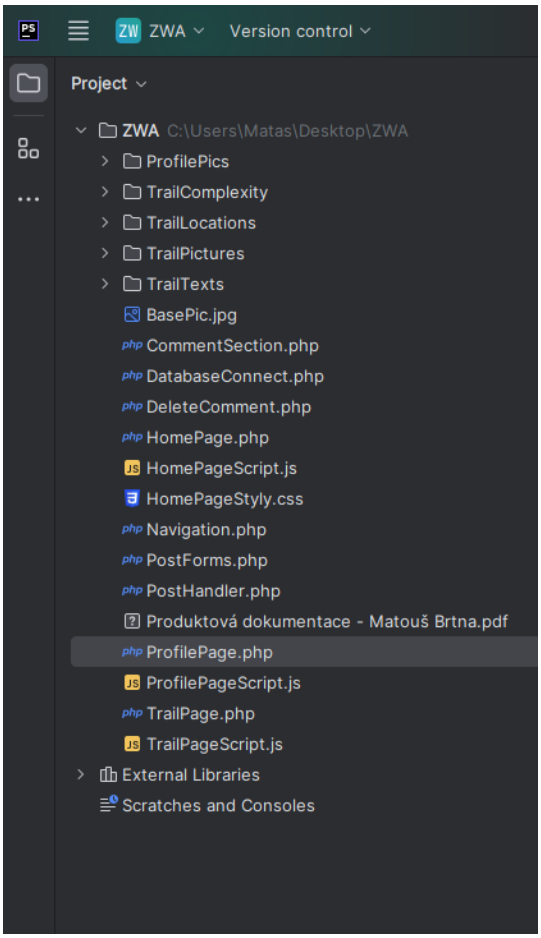




Tato webová aplikace je navržena především pro prohlížení na stolních počítačích a noteboocích. Styly jsou připraveny i pro otevření na malých obrazovkách jako je obrazovka telefonu, avšak používat se bude hůř než na stolním počítači.

2. Struktura

Kromě textů k trailům, jejich obrázků a obrázků uživatelů se vše nachází v jedné složce.



Stránky končící na slovo „Page“ jsou pak stránky ke kterým bude puštěn uživatel. Tyto stránky následně implementují zbytek scritpů. Nejdůležitější script pro tuto aplikaci je „PostHandler.php“, který v podstatě plní formu kontroleru. Každý formulář odesílá metodou „post“ své data právě na tento script. Následně je zde rozhodnuto o dalším chování aplikace a případně úpravy dat z databáze.

```php
 * @author    Matouš Brtna
 */

// Start a new session or resume the existing session
session_start();
if(isset($_POST["location"]) && $_POST['location']!=""){
    $location=$_POST["location"];
}


// Database connection parameters
$username = 'brtnamat';
$passwordToDb = 'webove aplikace';
$adress = 'localhost';
$db = 'brtnamat';

// Establish a connection to the MySQL database or terminate the script if connection fails
$connection = new mysqli($adress, $username, $passwordToDb, $db) or die("Neni připojení k databázi");




// Check if wanted action was posting comment
if(($_SERVER["REQUEST_METHOD"] == "POST") && isset($_POST["comment_submit"])) {

    if(isset($_SESSION["username"]) && isset($connection) && isset($location)){ // Checks if location is set
        $username = $_SESSION["username"];
        $message = $_POST["text"];
        $sql = "INSERT INTO comments (username, text, trailname) VALUES (?, ?, ?)";
        $stmt = mysqli_prepare($connection, $sql);
        mysqli_stmt_bind_param($stmt, types: "sss", &vars: $username, &vars: $message, $location);
        $result = mysqli_stmt_execute($stmt); // Execute SQL query
        mysqli_stmt_close($stmt);
    } else {
        if(isset($location)){
            header( header: "Location: TrailPage.php?location={$location}&errors=true"); // Moves user to loaction site if thats where it was called
            exit();
        }
    }
```

Po provedení všech akcí je formou post-redirect-get odeslán header na jiný patřičný script. Tento krok je proveden funkcí „header“.

```php
        mysqli_stmt_close($stmt);
    } else {
        if(isset($location)){
            header( header: "Location: TrailPage.php?location={$location}&errors=true"); // Moves user to loaction site if thats where it was called
            exit();
        }
    }
    header( header: "Location: TrailPage.php?location={$location}&page={$_POST['page']}"); // Otherwise it moves user to home page
    exit();
}
```

3. Přihlášení/Registrace

Po odeslání formuláře pro přihlášení nebo registraci na PostHandler, jsou hodnoty přesměrovány do funkcí loginValidation nebo registerValidation, kde následně pomocí sql query je kontrolováno jestli se takový uživatel může přihlásit. K takové situaci však dojde pouze pokud formulář prošel Javascript kontrolou délek zadaných hodnot.

```php
 * @param string $username    - The entered username.
 * @param string $password    - The entered password.
 * @param mysqli $connection  - The MySQL database connection.
 *
 * @return string             - Validation error message, if any.
 */

1 usage
function validateLogin($username, $password,$connection): string
{
    // Check if username or password is empty
    if (empty($username) || empty($password)) {
        return "Nezadané heslo nebo uživatelské jméno";
    }

    // Get all users from the database
    $users=getAllUsers($connection);

    // Loop through each user to find a match
    foreach ($users as $user){
        // Check if the username and password match
        if ($user["username"]==$username && password_verify($password,$user["password"])){
            // Set session variables for the logged-in user
            $_SESSION["username"]=$username;
            $_SESSION["admin"]=$user["admin"];
            return "";
        }
    }
    // Return error message if no matching user is found
    return "Špatné heslo nebo uživatelské jméno";
}



/**
 * Validates user registration details and inserts a new user into the database upon successful validation.
 *
 * @param string $username          - The entered username.
 * @param string $password          - The entered password.
 * @param string $confirmPassword   - The entered password confirmation.
 * @param string $firstName         - The entered first name.
```

```php
function KontrolaZadaniLog(event) : void {
    const FormularLog : ... = document.LoginForm.elements;
    let DelkaJmena = FormularLog.login_username.value.length;
    let DelkaHesla = FormularLog.login_password.value.length;
    let errors : any[] = [];
    if (DelkaJmena < 5 || DelkaJmena == null) {
        errors.push("Uživatelské jméno je příliš krátké")
        document.getElementById( elementId: "logUsernameLabel").className = "errorMessage"
    } else {
        document.getElementById( elementId: "logUsernameLabel").className = "ok"
    }
    if (DelkaHesla < 5 || DelkaHesla == null) {
        errors.push("Heslo je příliš krátké")
        document.getElementById( elementId: "logPasswordLabel").className = "errorMessage"
    } else {
        document.getElementById( elementId: "logPasswordLabel").className = "ok"
    }
    if(errors.length>0){
        let ErrorMessage : string ="";
        for(let i : number =0;i<errors.length;i++){
            let LastText : string =ErrorMessage;
            ErrorMessage=LastText+errors[i]+" "
        }
        alert(ErrorMessage);
        event.preventDefault()
    }
}

1+ usages
function KontrolaZadaniReg(event) : void {
    const FormularReg : ... = document.RegisterForm.elements;
    let DelkaUsername = FormularReg.register_username.value.length;
    let DelkaHesla =FormularReg.register_firstPassword.value.length;
    let heslo = FormularReg.register_firstPassword.value;
    let heslo_potvrzene=FormularReg.register_secondPassword.value;
    let errors : any[] =[];
    if(DelkaUsername<5 || DelkaUsername===undefined){
        errors.push("Délka uživatelského hesla musí být aspoň 5 znaků")
        document.getElementById( elementId: "regUsernameLabel").className="errorMessage"
    }else {
        document.getElementById( elementId: "regUsernameLabel").className="ok"
```

4. Vkládání do databáze

Aby vznikla ochrana proti SQL Injection je vyzužívána funkce my_sqli_prepare, která tomuto typu hackování zabrání. Jedná se o tzv. připravené dotazy

```
$sql = "INSERT INTO users (username, firstname, secondname, password, admin) VALUES (?, ?, ?, ?, ?)";
$stmt = mysqli_prepare($connection, $sql);
mysqli_stmt_bind_param($stmt, types: "ssssi", &vars: $username, &vars: $firstName, $lastName, $hashedPassword, $adminValue);
$result = mysqli_stmt_execute($stmt); // Executes SQL query
```

5. Ochrana proti Cross-site scripting

Každý výpis uživatelem vložených dat je uskutečněn za pomocí htmlspecialchars. Tímto se předejde spuštění vloženého scriptu.

```
25          if(isset($connection)){
26              $userInfo=GetUserInfo($connection);
27              echo "<h3> Uživatelské jméno: </h3>
28                  <p>".htmlspecialchars($userInfo[0]). "</p>";
29              echo "<h3> Jméno: </h3>
30                  <p>".htmlspecialchars($userInfo[1]). "</p>";
31              echo "<h3> Příjmení: </h3>
32                  <p>".htmlspecialchars($userInfo[2]). "</p>";
```

6. Komentáře a stránkování

Protože výpis všech komentářů na jednu stránku by mohl být časem příliš dlouhý, je implementováno server-side stránkování obsahu. Na jednu stránku s trailem se tedy vloží maximálně několik komentářů a na základě totálního počtu komentářů se vytvoří odkazy na další strany pod sekcí s komentáři.

```php
<?php

$itemsPerPage = 10; // Sets max number of commnents on site
$page = isset($_GET['page']) ? (int)$_GET['page'] : 1; // Gets page we are on

if (isset($location) && isset($connection)) {
    $offset = ($page - 1) * $itemsPerPage; // Calculates which comment should be first
    $sql = "SELECT * FROM comments WHERE trailname = ? LIMIT ? OFFSET ?";
    $stmt = mysqli_prepare($connection, $sql);
    mysqli_stmt_bind_param($stmt, types: "sii", &vars: $location, &vars: $itemsPerPage, $offset);
    mysqli_stmt_execute($stmt);
    $result = mysqli_stmt_get_result($stmt);
    $comments = mysqli_fetch_all($result, mode: MYSQLI_ASSOC); // Gets all comments in assoc field
    mysqli_stmt_close($stmt); // SQL pro získání komentářů

    foreach ($comments as $comment) {
        echo "<h3>";
        echo "Uživatel: " . htmlspecialchars($comment["username"]);
        echo "</h3>";
        echo "<br>";
        echo "<p class='comment' >";

        echo  htmlspecialchars($comment["text"]);
        echo "</p>";
        // Adds button for removing the comment if its alloved
        if( (isset($_SESSION['username']) && $comment["username"]===$_SESSION['username']) || (isset($_SESSION["admin"]) && $_SESSION["admin"]==1)){
            echo "<form method='post' action='PostHandler.php'>
                <input type='hidden' name='id' value='" . $comment["id"] . "'>
                <input type='hidden' name='location' value='" . $location ."'>
                 <input type='hidden' name='page' value='" . $_GET['page'] ."'>
                <button class='RemoveComment' name='DeleteComment'> Odstranit komentář </button>
            </form>";
        }
        echo "<br>";
    }
```

7. Údaje o uživateli

Pokud je uživatel přihlášen jsou informace o jeho jméně a právech uloženy v session, ta je tvořeno pokud se úspěšně přihlásil nebo registroval.

```php
if ($user["username"]==$username && password_verify($password,$user["password"])){
    // Set session variables for the logged-in user
    $_SESSION["username"]=$username;
    $_SESSION["admin"]=$user["admin"];
    return "";
```

8. Předvyplnění formuláře

Pokud se z nějakého důvodu uživatele nepovede správně vyplnit formulář registrační nebo přihlašovací, bude přesměrován zpátky na stránku ze které se pokoušel přihlásit. Formulář bude předvyplněn pro další pokus. Tyto data vrací PostHandler v podobě pole uloženého v session, které komentářová sekce využívá pro vyplňování hodnot.

```
<div class="VyskakovaciForm" id="RegDiv" >
    <form  name="RegisterForm" class="VyskakovaciForm" action="PostHandler.php" method="post">
        <label id="regUsernameLabel">Username: (povinné)
            <input type="text" placeholder="Username" value="<?php if(isset($_SESSION["formValues"]['register_username'])){
                echo htmlspecialchars($_SESSION["formValues"]['register_username']);
            }?>" class="Username" name="register_username">
        </label><br>
        <label >Jméno:
            <input type="text" placeholder="Jméno" value="<?php if(isset($_SESSION["formValues"]['register_firstName'])){
                echo htmlspecialchars($_SESSION["formValues"]['register_firstName']);
            }?>" class="Jmeno" name="register_firstName">
        </label><br>
        <label>Příjmení:
            <input type="text" placeholder="Příjmení" value="<?php if(isset($_SESSION["formValues"]['register_lasttName'])){
                echo htmlspecialchars($_SESSION["formValues"]['register_lastName']);
            }?>" class="Prijmeni" name="register_lastName">
        </label><br>
        <label id="regPasswordLabel">Heslo: (povinné)
            <input type="password" class="Heslo" placeholder="Heslo" value="<?php if(isset($_SESSION["formValues"]['register_firstPassword'])){
                echo htmlspecialchars($_SESSION["formValues"]['register_firstPassword']);
            }?>" name="register_firstPassword">
        </label><br>
        <label id="regConfirmPasswordLabel">Potvrdit heslo: (povinné)
            <input type="password" class="Heslo" placeholder="Heslo" value="<?php if(isset($_SESSION["formValues"]['register_secondPassword'])){
                echo htmlspecialchars($_SESSION["formValues"]['register_secondPassword']);
            }?>" name="register_secondPassword">
        </label><br>
        <input type="hidden" name="location" value="<?php if(isset($location)) {
            echo $location;} ?>">
        <input type="submit" value="Registrovat" name="register_submit" class="Odeslani">
        <input type="button" value="Zavrit" id="ZavreniReg">
    </form>
</div>
<?php
```